LINUX HOST PENETRATION TEST

ORION

Technical Penetration Testing Report

Prepared by: [Tester / Organization]
Report Version: 1.0
Date: [Insert date]
Classification: Confidential — Lab Use

Target: 10.129.244.146 (HTB lab address supplied in notes)

This report documents the attack path described in the supplied Orion walkthrough. Replace placeholders and validate evidence before using it as a formal client deliverable.

Document Properties

Property	Value
Title	Orion Linux Host Penetration Test Report
Version	1.0 — Draft
Author / Testers	[Insert name(s)]
Reviewed by	[Pending review]
Approved by	[Pending approval]
Classification	Confidential — Lab Use

Version Control

Version	Date	Author	Description
1.0	[Insert date]	[Tester]	Initial draft based on supplied walkthrough

Table of Contents

1. Executive Summary

  1.1 Scope of Work

  1.2 Project Objectives

  1.3 Assumptions and Limitations

  1.4 Timeline

  1.5 Summary of Findings

  1.6 Summary of Recommendations

2. Methodology

  2.1 Planning and Enumeration

  2.2 Exploitation and Validation

  2.3 Reporting

3. Detailed Findings

  3.1 Target System Information

  3.2 CraftCMS Remote Code Execution

  3.3 Exposure of Database Credentials

  3.4 Weak / Reused User Password

  3.5 Telnet Authentication Bypass / Root Escalation

4. References

Appendix A. Evidence Checklist

Appendix B. Glossary

1. Executive Summary

This report summarizes a penetration test of the Orion Linux host in a Hack The Box lab. The supplied walkthrough describes a chained compromise beginning with a web application vulnerability in CraftCMS, followed by recovery of database credentials from an application environment file, cracking of a bcrypt password hash associated with the user adam, SSH access through password reuse, and local privilege escalation through a vulnerable Telnet service.

The described attack chain culminated in root-level access. This demonstrates that a remotely exploitable web application, insufficient protection of application secrets, weak or reused credentials, and a vulnerable local service can combine to compromise the host. The severity ratings below are provisional and should be confirmed against the engagement's agreed risk methodology and supporting evidence.

1.1 Scope of Work

Item	Details
Target	Orion Linux host
Target IP	10.129.244.146 (as provided in the walkthrough; lab IPs can change)
Services observed	TCP/22 SSH and TCP/80 HTTP from the described Nmap scan
Application	CraftCMS, version reported as 5.6.16
Testing type	Lab-based host penetration test; exact engagement type not supplied
Out of scope	Other hosts, networks, denial-of-service testing, persistence, and activities not described in the supplied walkthrough

1.2 Project Objectives

• Identify externally reachable services and the exposed web application.

• Determine whether the application can be exploited to obtain an initial foothold.

• Assess whether application configuration or database contents expose reusable credentials.

• Assess local privilege boundaries and the possibility of escalation to root.

• Provide prioritized remediation recommendations.

1.3 Assumptions and Limitations

This draft is based on the user-provided walkthrough, not on an independent retest or a complete evidence package. Screenshots, exact command outputs, timestamps, hashes, and the full Nmap/Gobuster/Metasploit output were not supplied. The exact operating-system build, CraftCMS deployment configuration, Telnet server package/version, and exploit success evidence therefore require confirmation. The reported CVE mappings are recorded as described in the walkthrough and should be verified before this report is used outside the lab.

1.4 Timeline

Activity	Start	End	Status
Reconnaissance and enumeration	[Insert]	[Insert]	Reported completed
Web exploitation and foothold	[Insert]	[Insert]	Reported completed
Credential and database review	[Insert]	[Insert]	Reported completed
SSH user access	[Insert]	[Insert]	Reported completed
Privilege escalation and validation	[Insert]	[Insert]	Reported completed

1.5 Summary of Findings

ID	Finding	Provisional severity	Basis
ORION-01	CraftCMS remote code execution (CVE-2025-32432 as reported)	Critical	Described remote code execution and initial foothold
ORION-02	Application environment file exposes database credentials	High	Credentials reportedly recovered from .env and used to access MySQL
ORION-03	Crackable bcrypt hash and password reuse enables SSH as adam	High	Hash reportedly cracked and password accepted for SSH
ORION-04	Vulnerable Telnet service permits authentication bypass to root (CVE-2026-24061 as reported)	Critical	Walkthrough reports root shell through crafted USER value

Severity labels are preliminary, qualitative ratings for this lab report—not a CVSS calculation. Final ratings should consider exposure, prerequisites, impact, and the organization's risk-rating policy.

1.6 Summary of Recommendations

- Upgrade CraftCMS and affected dependencies to a vendor-supported version containing the relevant security fix; verify the exact affected version and advisory.
- Restrict access to .env and other secret-bearing configuration files; rotate any exposed database credentials and store secrets in a managed secret store where appropriate.
- Use unique, strong passwords for operating-system and application accounts; enable MFA where supported and review password-hash configuration.
- Remove or upgrade the vulnerable Telnet service. Prefer SSH for administration and restrict management services to approved interfaces and source addresses.
- Review logs for exploitation indicators, rotate credentials potentially exposed during testing, and retest after remediation.

2. Methodology

The report follows a planning, exploitation, and reporting structure similar to the sample report in the supplied reference PDF. The workflow described below is based on the provided Orion walkthrough.

2.1 Planning and Enumeration

An Nmap scan using service/version detection and default scripts identified TCP/22 (SSH) and TCP/80 (HTTP). The hostname orion.htb was mapped to the target address in /etc/hosts to support hostname-based web access. Gobuster directory enumeration identified /admin/login and /assets. The login page disclosed CraftCMS 5.6.16.

2.2 Exploitation and Validation

The walkthrough reports use of a Metasploit module targeting CVE-2025-32432 to obtain a shell. After obtaining the shell, the tester reviewed application configuration, used the database credentials found in .env to access MySQL, extracted a bcrypt hash from the users table, cracked the hash with Hashcat, and tested the recovered password for SSH access as adam. Local socket enumeration then identified a listener on TCP/23. The walkthrough reports exploitation of CVE-2026-24061 through the Telnet login handling path to obtain root access.

2.3 Reporting

Findings are described with a title, severity, affected component, evidence summary, root cause, impact, and recommendations. Before final delivery, attach relevant screenshots and sanitized command output, validate the CVE details and versions, and obtain a technical peer review.

3. Detailed Findings

3.1 Target System Information

Attribute	Observed / reported value
Hostname	orion.htb
Target IP	10.129.244.146 (from supplied walkthrough)
Operating system	Linux; exact distribution and version not provided
TCP/22	SSH — open
TCP/80	HTTP — open
Web application	CraftCMS 5.6.16 as displayed on the admin login page
TCP/23	Telnet listener discovered locally after user access; external exposure not established

Evidence to attach: complete Nmap output, screenshot of the CraftCMS version, Gobuster results, and output of the local listening-socket enumeration.

ORION-01: CraftCMS Remote Code Execution

Field	Details
Finding ID / Severity	ORION-01 / Critical (provisional)
Affected component	CraftCMS 5.6.16 web application reachable over HTTP
Description	The walkthrough identifies the CraftCMS version as 5.6.16 and reports successful exploitation associated with CVE-2025-32432, resulting in remote command execution and an initial shell on the host.
Evidence reported	The walkthrough reports the version from /admin/login and a successful Metasploit exploitation session. Insert the exact request/session output and a screenshot demonstrating the effective shell identity.
Root cause	A vulnerable application version and unsafe handling of the affected image-processing / asset-transformation request path, as described in the walkthrough.
Impact	An unauthenticated or otherwise insufficiently authorized remote attacker may execute commands in the web application's security context, potentially enabling further host compromise.
Recommendation	Upgrade to a verified fixed vendor release; review the official advisory and dependency versions; restrict the application's exposure where feasible; monitor for suspicious asset-transform requests; and retest.

Validation note: Confirm the CVE applicability against the exact CraftCMS build and the Metasploit module documentation before finalizing.

ORION-02: Exposure of Database Credentials in .env

Field	Details
Finding ID / Severity	ORION-02 / High (provisional)
Affected component	CraftCMS host filesystem and MySQL database
Description	After obtaining a shell, the walkthrough reports finding a .env file containing credentials used by the application to connect to MySQL.
Evidence reported	The walkthrough states that the credentials were used to connect with `mysql -u root -p orion`. Attach a redacted screenshot or output proving file access and successful database authentication; do not include live secrets in the report.
Root cause	Secret-bearing configuration was readable by the compromised execution context and database credentials were available in the application environment file.
Impact	An attacker with application-level command execution may

	access database contents, including user account records and password hashes, and may use the credentials beyond the intended application context depending on database privileges.
Recommendation	Restrict file permissions and service-account access; remove unnecessary database superuser privileges; rotate exposed credentials; use separate least-privileged database accounts; and use an approved secrets-management process.

Validation note: The exact database grants and file permissions were not included in the supplied notes and should be validated.

ORION-03: Crackable Password Hash and Password Reuse

Field	Details
Finding ID / Severity	ORION-03 / High (provisional)
Affected component	MySQL users table and Linux account adam
Description	The walkthrough reports extracting a bcrypt hash for adam, recovering its password with Hashcat and a wordlist, and successfully using the recovered password to authenticate over SSH as adam.
Evidence reported	Attach sanitized evidence showing the hash type, Hashcat result with the recovered secret redacted, and successful SSH login. Do not publish plaintext passwords or full password hashes in a widely distributed report.
Root cause	A password was sufficiently guessable to be recovered offline, and the same password was reportedly reused for SSH.
Impact	An attacker who obtains the database hash may recover the password and gain a separate operating-system login, establishing a more persistent and convenient foothold.
Recommendation	Set a unique, high-entropy password for each account and service; change the affected password immediately; review password-hashing parameters and account exposure; consider MFA for SSH; and alert on unusual logins.

Validation note: Confirm that the recovered password was the same credential accepted by SSH and record the account's effective permissions.

ORION-04: Telnet Authentication Bypass Leading to Root

Field	Details
Finding ID / Severity	ORION-04 / Critical (provisional)
Affected component	Local Telnet service on TCP/23 and the associated login process
Description	After SSH access as adam, the walkthrough reports a local listener on TCP/23 and an authentication-bypass exploit associated with CVE-2026-24061. The crafted USER environment value is reported to have resulted in a root shell.
Evidence reported	The walkthrough gives `ss -lntp` as the discovery command and reports use of `env USER='-f root' telnet -a 127.0.0.1 23`. Attach sanitized output showing the listener, server package/version evidence, and `id`/`whoami` output from the resulting shell.
Root cause	The affected Telnet server/login path reportedly mishandles a specially crafted USER value so that it is interpreted as an option during login handling, allowing authentication to be bypassed.
Impact	A local user who can reach the vulnerable service may be able to obtain root privileges, resulting in full host compromise and access to protected data and system

	configuration.
Recommendation	Disable and remove Telnet if not required; upgrade the affected server package to a verified fixed release; restrict management services to approved interfaces; prefer SSH; and investigate logs for suspicious local Telnet connections.

Validation note: The walkthrough's `telnet --version` command may identify the client rather than the server. Verify the installed server package, exact vulnerable component, and CVE advisory before asserting confirmed version-level exposure.

4. References

• User-provided Orion machine walkthrough (source notes supplied in the conversation).

• CraftCMS advisory for CVE-2025-32432: verify and insert the official vendor/security advisory URL before final delivery.

• CVE-2026-24061 and the referenced proof-of-concept repository: https://github.com/Chocapikk/CVE-2026-24061 (validate the repository and advisory details before client distribution).

• Official vendor advisories and package changelogs for the affected CraftCMS and GNU Inetutils/Telnet components should be added after version verification.

Appendix A. Evidence Checklist

- Nmap scan output with date/time and target IP.
- Relevant /etc/hosts mapping (redact unrelated entries).
- Gobuster output showing discovered paths.
- CraftCMS version evidence from the login page.
- Metasploit module name/options and sanitized session proof.
- Redacted .env evidence proving exposed database configuration (never include live secrets).
- Sanitized MySQL output showing the relevant table/record without disclosing the full hash.
- Hashcat mode and successful result with the plaintext password redacted.
- SSH login evidence for adam and user-flag proof only if permitted by lab rules.
- Local listening-socket output and evidence identifying the Telnet server package/version.
- Root proof showing `id`/UID 0, with flags and sensitive data redacted.
- Retest results after remediation.

Appendix B. Glossary

Term	Meaning
RCE	Remote Code Execution: ability to cause a remote system to execute attacker-controlled commands or code.
CMS	Content Management System; software used to manage website content.
.env	Configuration file that may contain environment variables and secrets.
bcrypt	Password-hashing algorithm designed to make password guessing more expensive.
SSH	Encrypted protocol for remote shell access.
Telnet	Legacy remote terminal protocol; traditional Telnet does not encrypt traffic.
Privilege escalation	Obtaining permissions beyond those initially available, such as moving from a normal user to root.
Root	The Linux superuser, conventionally UID 0.